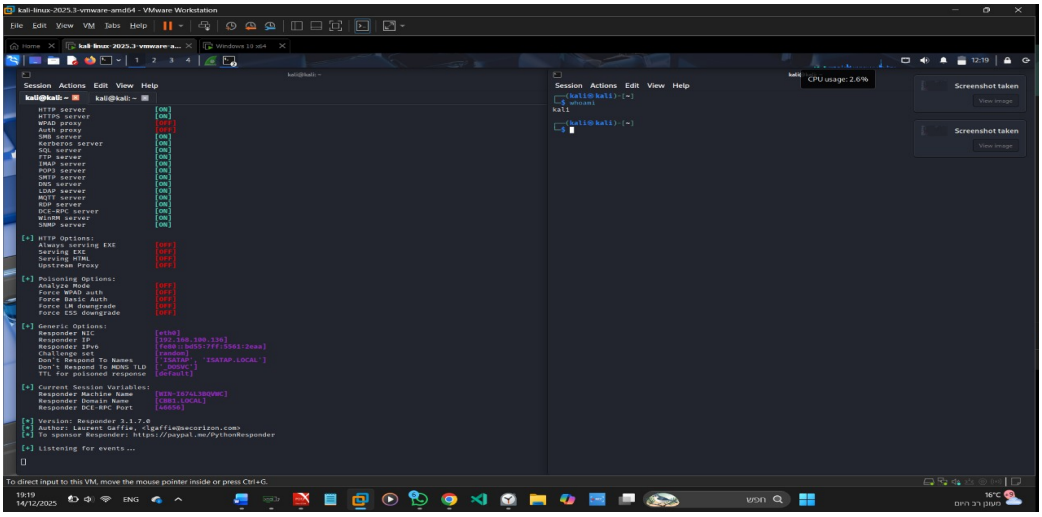
LAB REPORT – LLMNR Poisonig\ אקלו אזגה

תקציר
בדוח הזה אני הראה חולשה שנמצא במערכת WINDOWS כאשר משתמשים בפרוטקולים של LLMNR שעל ידיה התקוף יכול להתחזות לשרת האמין ולגרום למתשמש לשלוח פרטי אימות מבוססי NTLM על ידי התדגמה מעשיתי וגם שימוש ב Wireshark ופתרון לבעיה.

שלב ראשון: הכנות לתקפת LLMNR poiosng

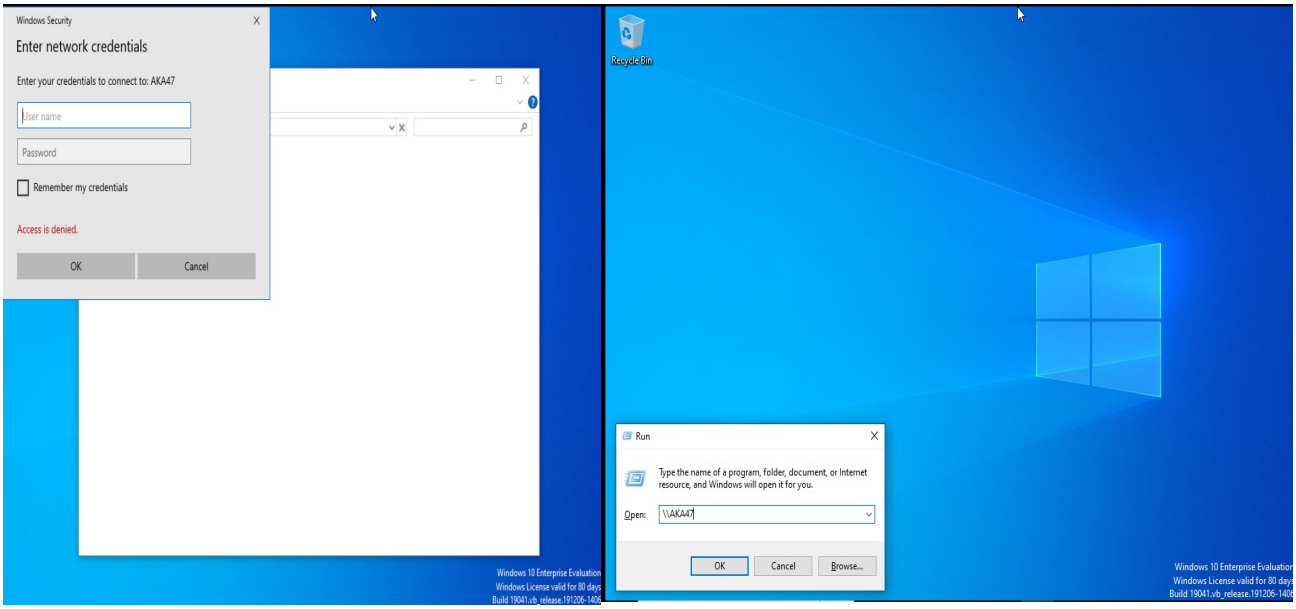
התקוף שנקרא אלמוג מפעיל אצילו ב kali כלי ההזנה שנקרא Responder
פקודה היא: **sudo responder -I eth0**

שמאפשרת לו להזין למתרחש ברשת ובגלל שהוא מחובר איתם על אותו רשת. הוא מחכה לרגע שמישהו יבקש גישה לשרת ויטעה בשם שלו או שהשרת לא ימצא.



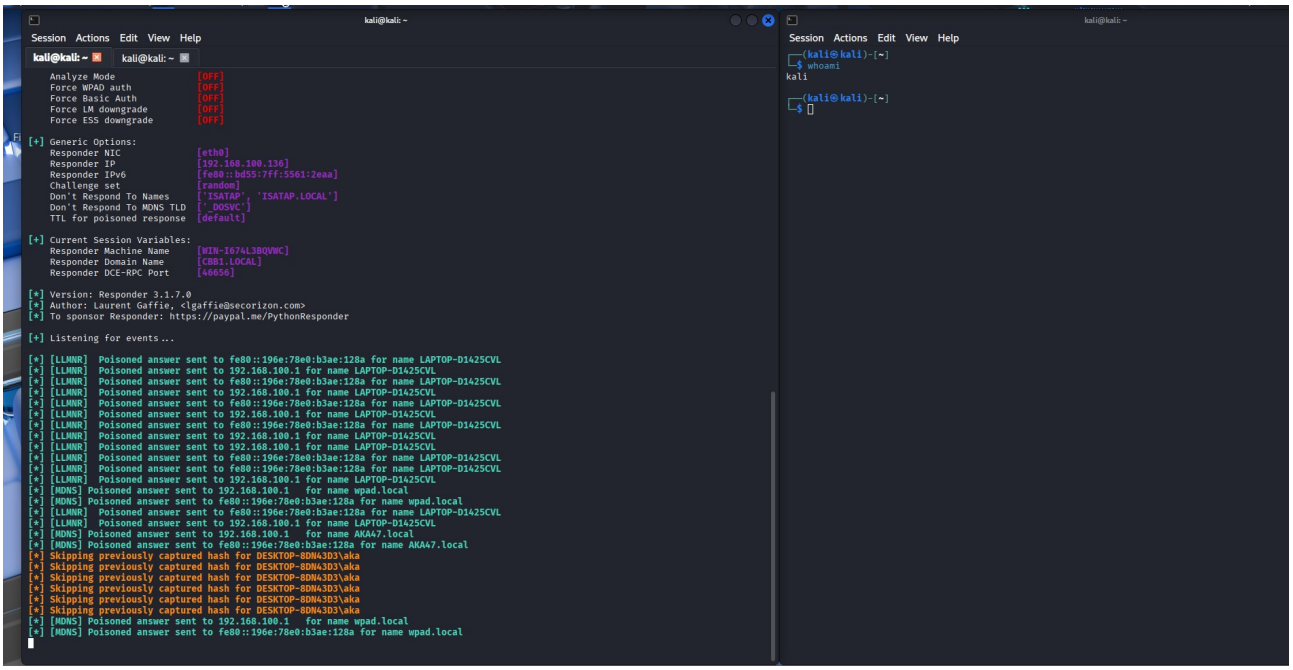
שלב שני: טעות במציאת DNS ושימוש בפרוטוקול LLMNR

משתמש בשם מרדכי מחפש שרת שנקרא AKA47\\ והוא לא מצליח למצוא.

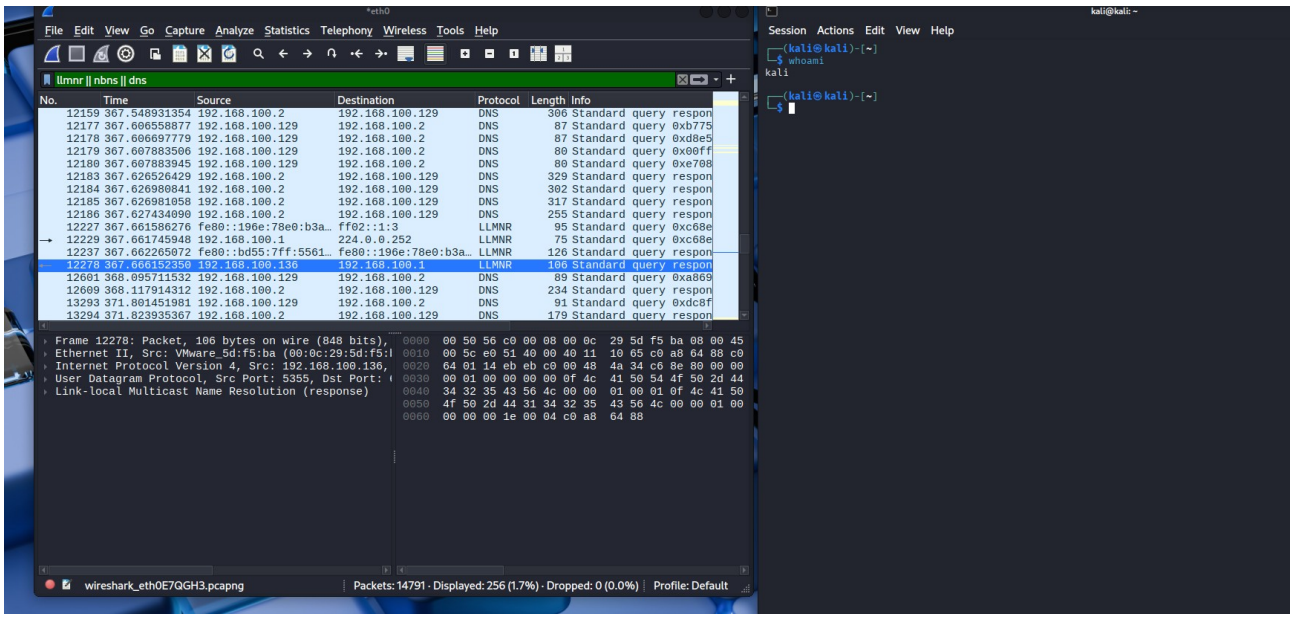


שלב 3: התוקף משיג את HASH

בגלל ששרת DNS לא מצליח למצוא את השרת, עוברים מחפש בעזרת פרוטוקול LLMNR ששלוח בקשות MULUCAST לכל המחשבים ברשת והתקוף (אלמוג) עונה לו שהוא השרת ובגלל ששאין לו יכולת אימות והמחשב מבצע תהליך אימות עם המחשב של התוקף (אלמוג) וכדי להזדהות מרדכי שולח לו את HASH



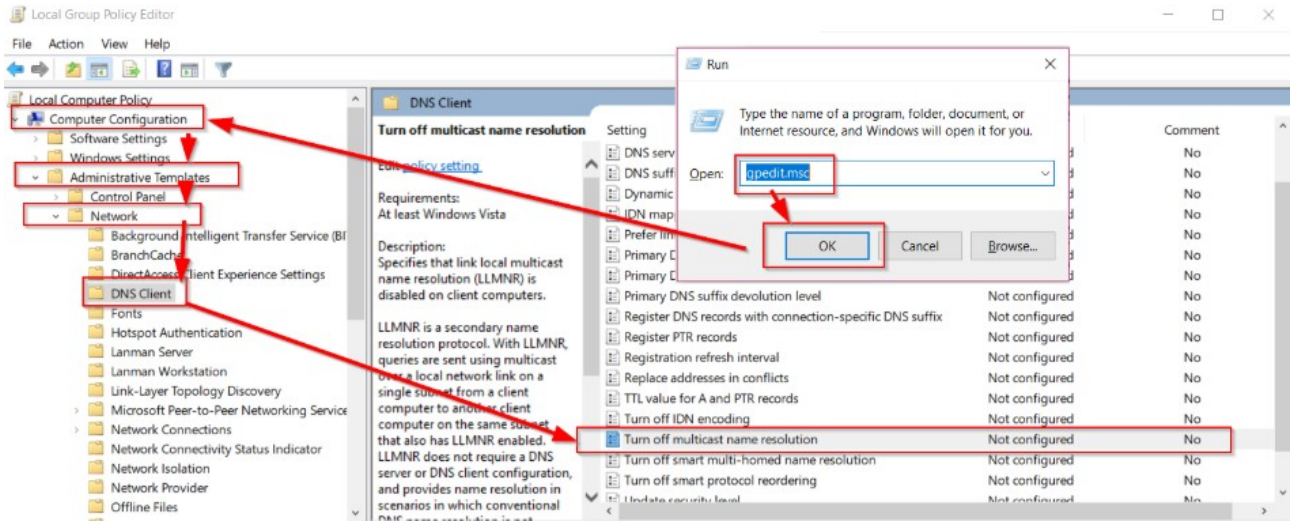
שלב 4: הוכחה בwireshrak



12185	367.626981058	192.168.100.2	192.168.100.129	DNS	317	Standard query respon
12186	367.627434090	192.168.100.2	192.168.100.129	DNS	255	Standard query respon
12227	367.661586276	fe80::196e:78e0:b3a…	ff02::1:3	LLMNR	95	Standard query 0xc68e
12229	367.661745948	192.168.100.1	224.0.0.252	LLMNR	75	Standard query 0xc68e
12237	367.662265072	fe80::bd55:7ff:5561…	fe80::196e:78e0:b3a…	LLMNR	126	Standard query respon
12278	367.666152350	192.168.100.136	192.168.100.1	LLMNR	106	Standard query respon
12601	368.095711532	192.168.100.129	192.168.100.2	DNS	89	Standard query 0xa869

רואים כאשר הפרוטוקול DNS נכשל עוברים להשתמש ב LLMNR ששלוח פעמים בקשת MULTCAST פעם אחת ב IP4 שכתובת 224.0.0.252 ופעם אחת ב IP6 ואז המחשב של אלמוג (התקוף) עונה עם כתובת 192.168.100.136

שלב 5 פתרון לבעיה



Mitigation:

הדרך הכי טוב לפתור את הבעיה עד שיצא עדכון יותר טוב היא על ידי השבת פרוטוקול באמצעות GPO כמו שרואים בתמונה למעלה.